



AWS IAM Access Management & Governance Lab Project

Implementing RBAC, Least Privilege, JML, Access Review and Incident Troubleshooting



IAM



S3



EC2



CloudTrail



CloudWatch



Policy Simulator



Credential Report



1. Project Overview

What the lab is designed to demonstrate

Build and validate an AWS IAM access governance model in a single AWS account. Apply RBAC and least privilege instead of unnecessary individual permissions. Demonstrate Joiner / Mover / Leaver access lifecycle controls. Troubleshoot IAM AccessDenied incidents using Policy Simulator and CloudTrail. Perform access review and retain/remove decisions with documented evidence. All implementation and validation are manual; automation is future scope.

Core idea

Turn access management from an ad-hoc permission task into a controlled, reviewable process.

Evidence principle

Every major control is backed by an AWS Console screenshot or documented ticket/review evidence.

2.Source Problem

The project simulates organizational access-control failures

01 - Unmanaged lifecycle

Users join, move departments or leave without access being properly provisioned, changed or removed.

02 - Excess Permissions

Access is broader than the user's role and violates least privilege.

03 - No periodic review

Unnecessary permissions can remain unnoticed when access is not periodically reviewed.

04 - AccessDenied incidents

A user lacks a required permission; the root cause must be traced and fixed without granting excessive access.

Project response

AWS IAM + groups + RBAC + lifecycle tickets + access reviews + Policy Simulator + CloudTrail.

Who has the problem

security and IT teams who run access, managers who approve it, and auditors who check it.

Solution and What I Built

Solution

- Groups (RBAC), not individuals
- Least-privilege custom policies
- MFA for every user
- Joiner / Mover / Leaver with tickets
- CloudTrail + Simulator troubleshooting
- Periodic access review

What I built

- 4 users, 4 groups
- 5 custom policies, 1 role
- Password policy and MFA enforcement
- 7 tickets (IAM-001 to IAM-007)
- Access review with findings

5. Environment & Tools

Hands-on lab environment

AWS IAM

Users, groups, roles, custom policies, MFA

EC2

View-only access tests; no servers launched

Policy Simulator

Validate allow/deny behavior

CloudWatch

Read-only support scenario

S3

Private bucket for access tests

CloudTrail

View-only support scenario

Credential Report

Access review evidence

6. Architecture

Access flows through identity → group → policy → resource

IAM Users

- alice
- bob
- charlie
- aws-suri

Groups / Roles

- Finance-group
- Developer-group
- Support-group
- LabAdmins
- FinanceS3ReadRole

Policies

- RBAC
- custom least-privilege
- RequireMFA
- AllowAssumeFinanceS3Read Role

AWS Resources

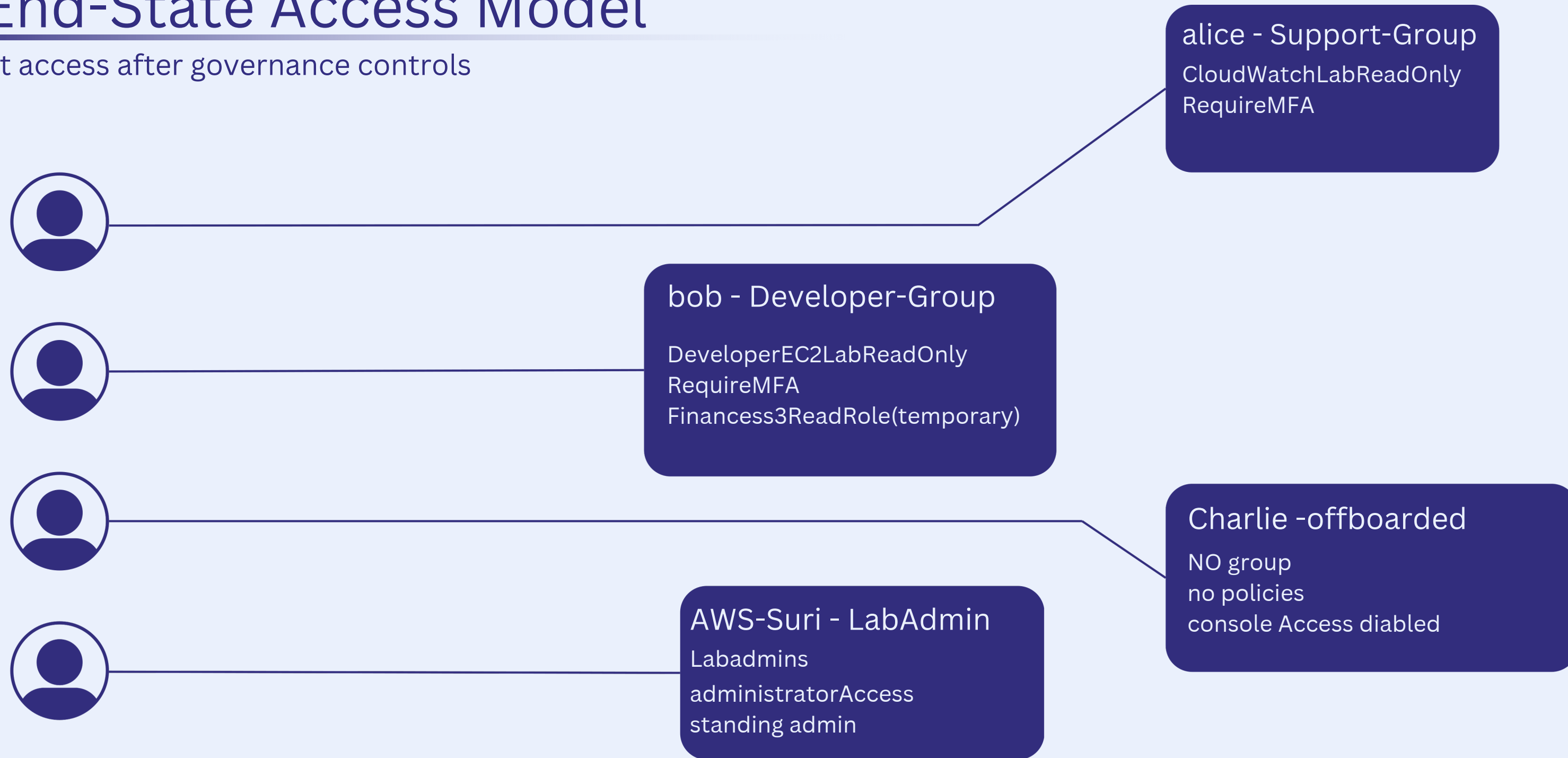
- S3
- EC2
- CloudWatch

Governance & evidence

- CloudTrail event history records management activity • Policy Simulator validates decisions • Credential Report supports review • Tickets document lifecycle and incidents.

7. End-State Access Model

Target access after governance controls



Governance rule

Access should be explainable by role, limited to business need, reviewed periodically, and removable through a documented lifecycle process.

8.Users & Groups

Identity and Access Management (IAM)

Search IAM

Dashboard

Access Management

Roles

Policies

IAM users

IAM user groups

Identity providers

Account settings

Root access management

IAM users (4)

Info

Refresh

Delete user

Create user

Search

< 1 >

Settings

User name

▲

Path

▼

Group

▼

Last activity

▼

MFA

▼

Password age

▼

Console last sign-in

▼

Access key ID

▼

Active key age

▼

Access key last used

▼

☐	alice	/	0	-	-	-	-	-	-	-
☐	aws-suri	/	1	✔ 17 minutes ago	Virtual...	✔ 40 days	✔ 17 minutes ago	-	-	-
☐	bob	/	1	-	-	-	-	-	-	-
☐	charlie	/	1	-	-	-	-	-	-	-

State at setup, before the joiner ticket (alice has no group yet)

Identity and Access Management (IAM)

Search IAM

Dashboard

Access Management

Roles

Policies

IAM users

IAM user groups

Identity providers

Account settings

Root access management

IAM user groups (4)

Info

Refresh

Delete

Create group

Search

< 1 >

Settings

Group name

▲

Users

▼

Permissions

▼

Creation time

▼

☐	Developer-Group	1	✔ Defined	2 days ago
☐	Finance-Group	⚠ 0	✔ Defined	2 days ago
☐	LabAdmins	1	✔ Defined	2 days ago
☐	Support-Group	1	✔ Defined	2 days ago

Group / policy access configuration

Least privilege:before

- Finance-Group
- Developer-Group
- Support-Group

Search IAM

Dashboard

Access Management

- Roles
- Policies
- IAM users
- IAM user groups
- Identity providers
- Account settings
- Root access management
- Temporary delegation requests

Access reports

- Access Analyzer
- Resource analysis

Summary

User group name: Finance-Group

Creation time: October 05, 2026, 13:12 (UTC+05:30)

ARN: arn:aws:iam::[redacted]:group/Finance-Group

Users | Permissions | Access Advisor

Permissions policies (1) Info

You can attach up to 10 managed policies.

Search

Filter by Type: All types

☐	Policy name	Type	Attached entities
☐	AmazonS3ReadOnlyAccess	AWS managed	1

Search IAM

Dashboard

Access Management

- Roles
- Policies
- IAM users
- IAM user groups
- Identity providers
- Account settings
- Root access management
- Temporary delegation requests

Access reports

- Access Analyzer
- Resource analysis

Summary

User group name: Developer-Group

Creation time: October 05, 2026, 13:12 (UTC+05:30)

ARN: arn:aws:iam::[redacted]:group/Developer-Group

Users (1) | Permissions | Access Advisor

Permissions policies (1) Info

You can attach up to 10 managed policies.

Search

Filter by Type: All types

☐	Policy name	Type	Attached entities
☐	AmazonEC2ReadOnlyAccess	AWS managed	1

Search IAM

Dashboard

Access Management

- Roles
- Policies
- IAM users
- IAM user groups
- Identity providers
- Account settings
- Root access management
- Temporary delegation requests

Access reports

- Access Analyzer
- Resource analysis

Summary

User group name: Support-Group

Creation time: October 05, 2026, 13:13 (UTC+05:30)

ARN: arn:aws:iam::[redacted]:p/Support-Group

Users (1) | Permissions | Access Advisor

Permissions policies (1) Info

You can attach up to 10 managed policies.

Search

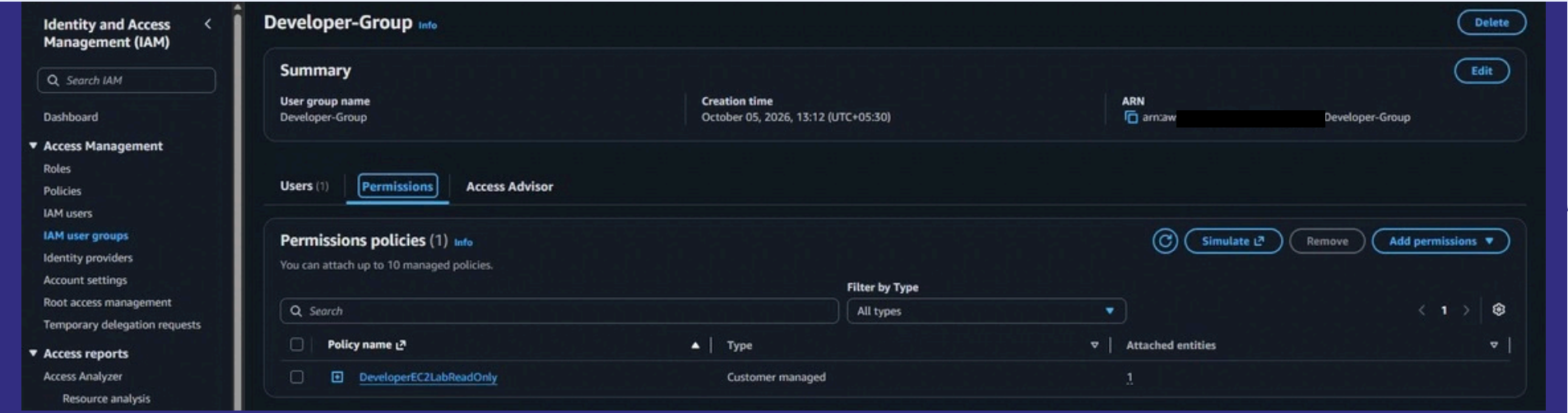
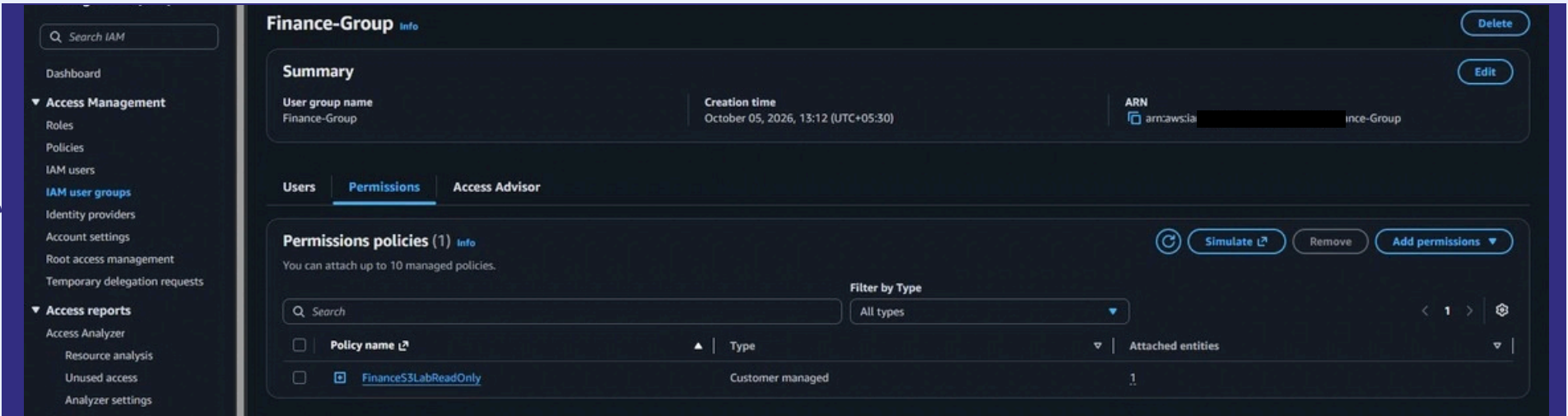
Filter by Type: All types

☐	Policy name	Type	Attached entities
☐	CloudWatchReadOnlyAccess	AWS managed	1

Least Privilege: Before , Before: AWS managed read-only policies attached to each group.

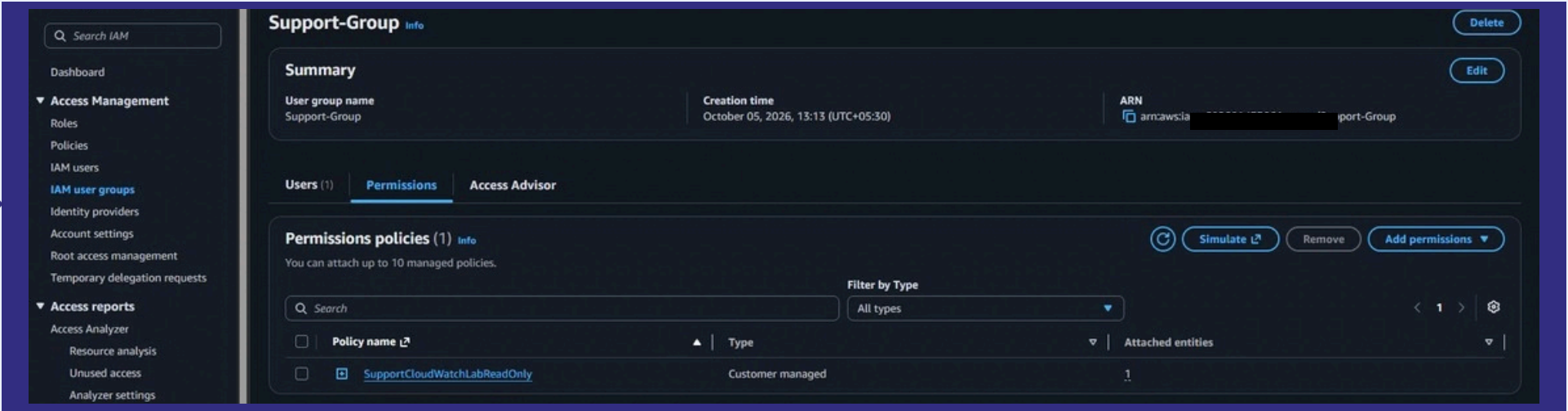
9. Least Privilege: After

Finance-Group



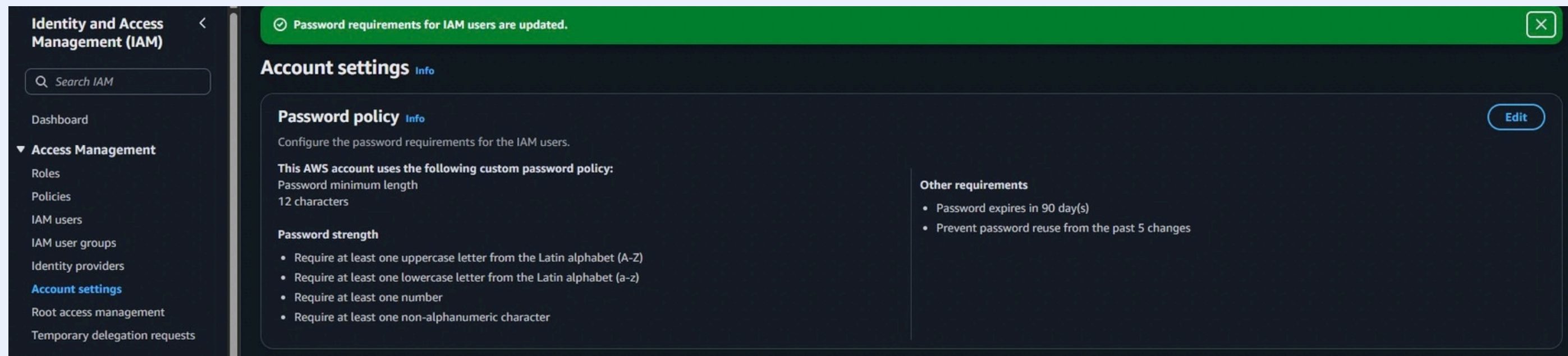
Developer-Group

Support-Group



After: custom policies sized to each job replace the managed policies.

10.MFA and Password Policy

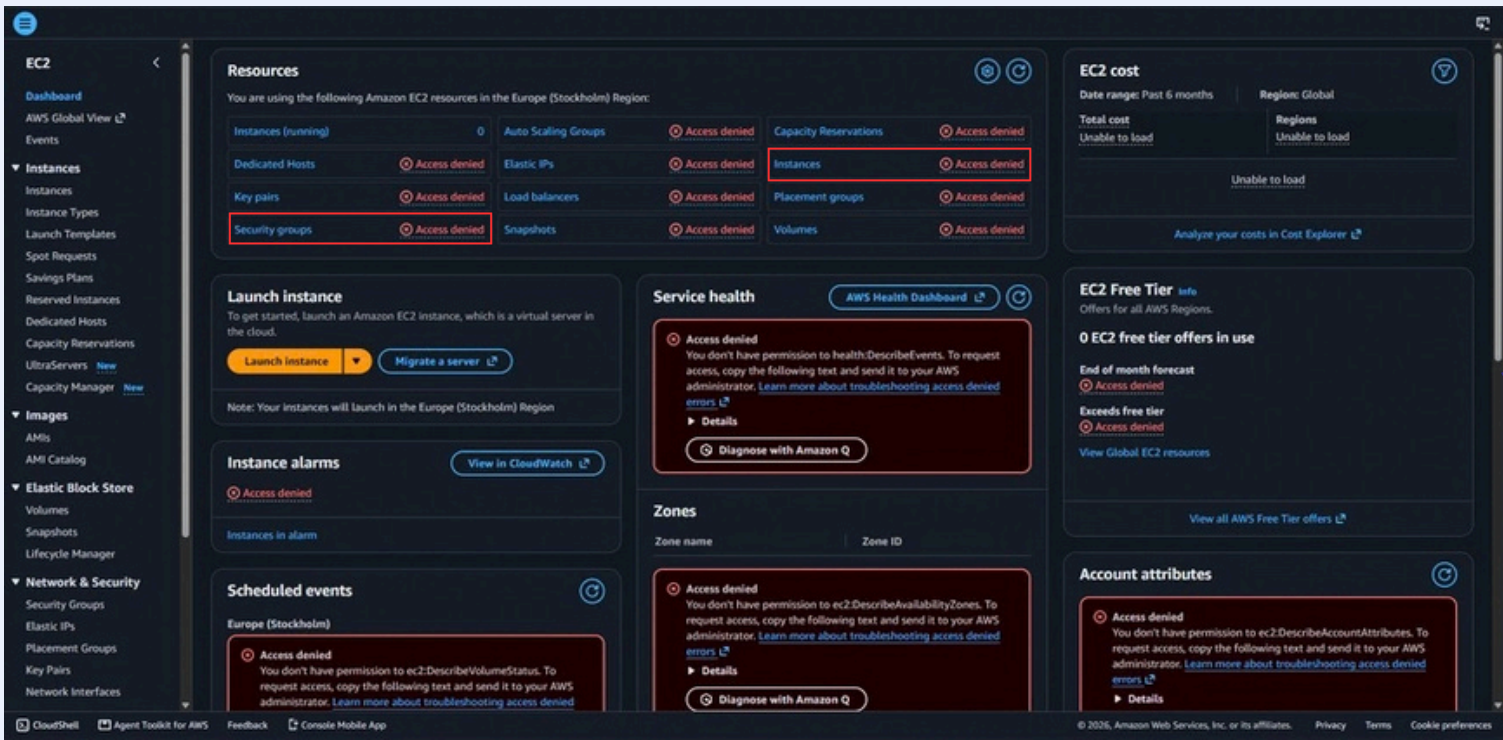


Account password policy



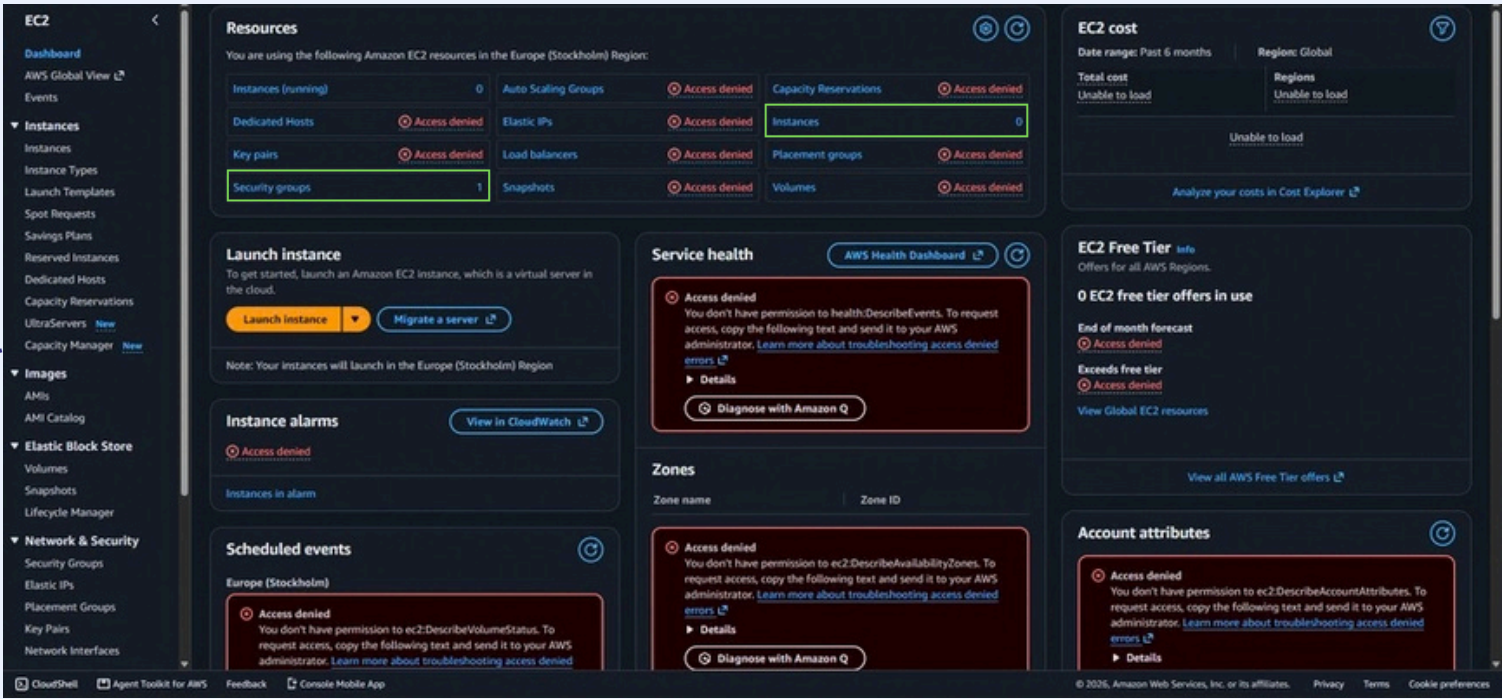
RequireMFA: deny everything except MFA setup when aws:MultiFactorAuthPresent is false.

MFA Test: Blocked, Then Allowed



explicit deny from RequireMFA

Bob with MFA: permitted calls load



Tickets and Lifecycle Process:

Ticket	Type	User	Purpose	Status
IAM-001	Joiner	alice	Finance onboarding	Closed
IAM-002	Mover	alice	Finance to support	Closed
IAM-003	Leaver	charlie	Offboarding	Closed
IAM-004	Incident	bob	EC2 Volume denied	Closed
IAM-005	Role access	bob	Temporary finance bucket access	Closed
IAM-006	Incident	bob	S3 file read denied	Closed
IAM-007	Security	all	MFA and Password standards	Closed

Flow bar:



IAM-001 : New hire onboarding, Finance

Type	Joiner
User	Alice
Requested by	Finance Manager
Approved by	IAM Admin
Date	05-10-26
Status	Closed

Request

- New hire in Finance needs access to the finance bucket only.

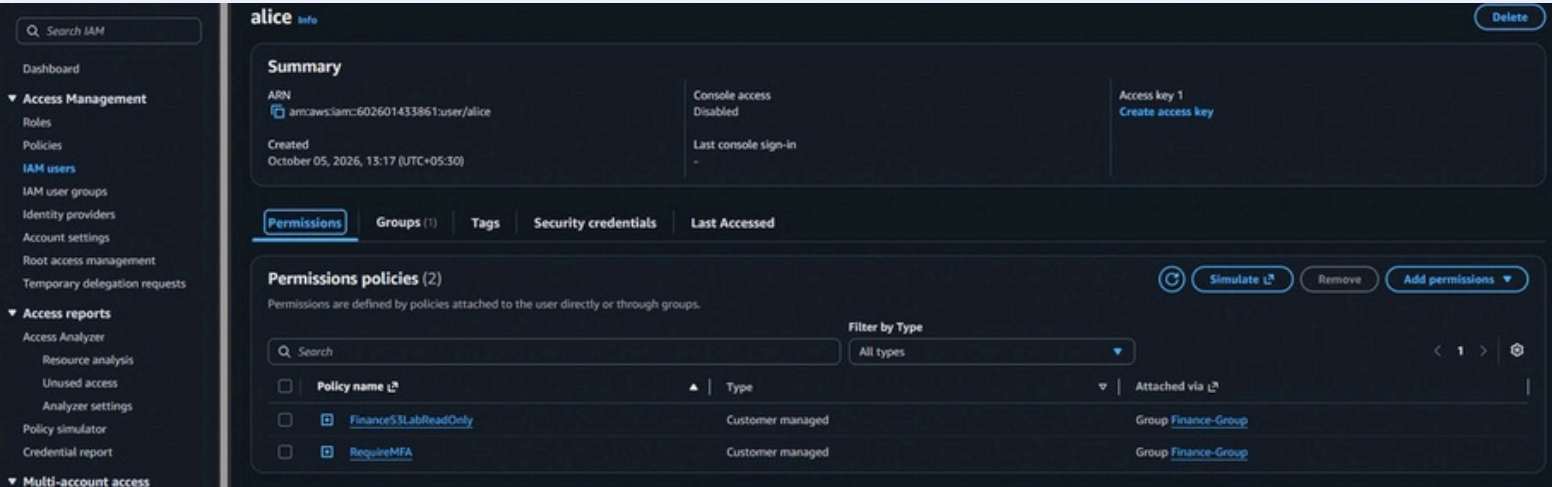
Action taken

- Baseline checked: no groups and no policies , Added alice to Finance-Group

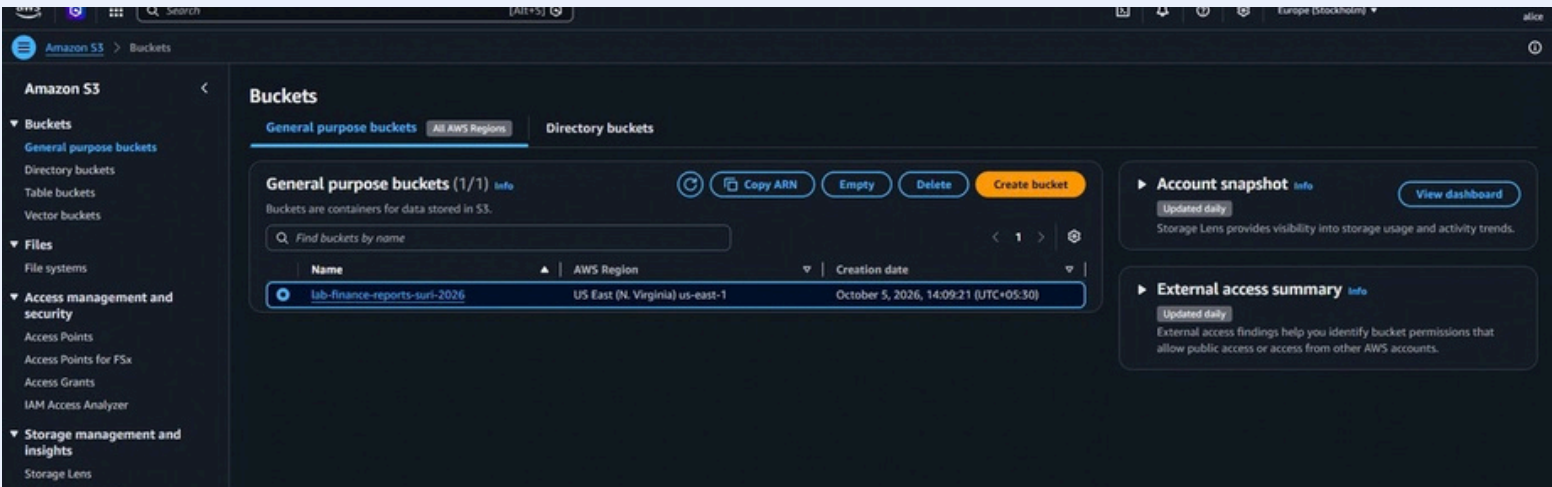
Verification

- Signed in with MFA
- Finance bucket readable
- EC2 denied, as expected (outside her role)

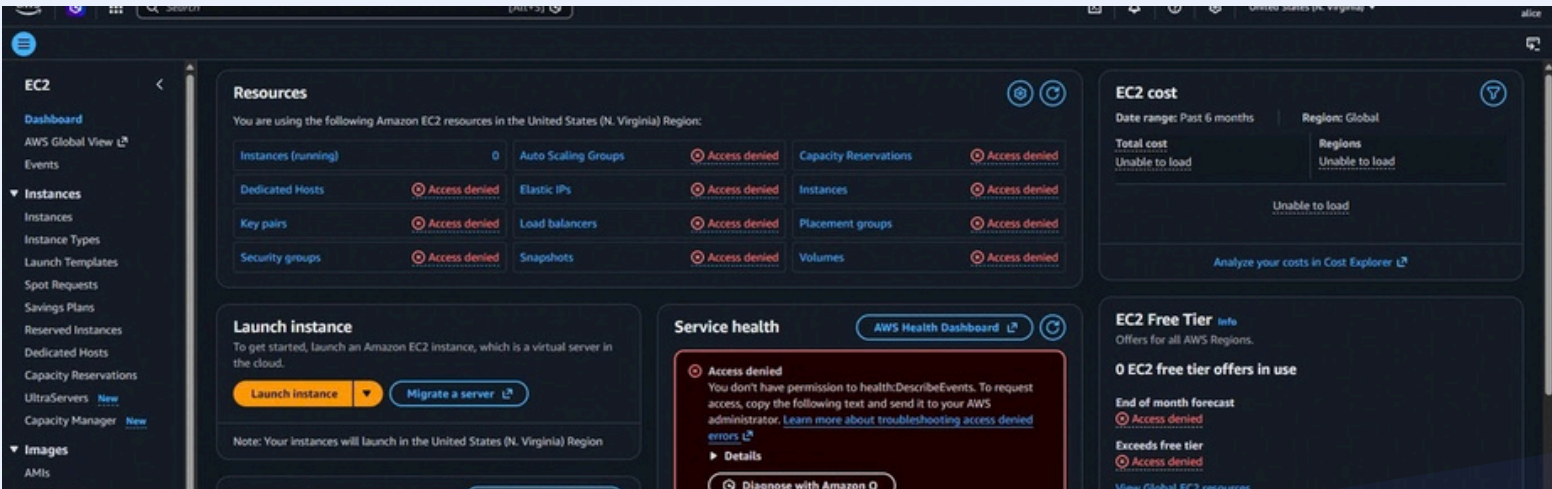
alice added to Finance-Group



alice access test: bucket allowed, EC2 denied



alice ,EC2 denied



IAM-002 : Transfer from Finance to Support

Type	Mover
User	Alice
Requested by	Approved
by Date	05-10-26
Status	Closed

Request

- alice moves from Finance to Support and must not keep Finance access.

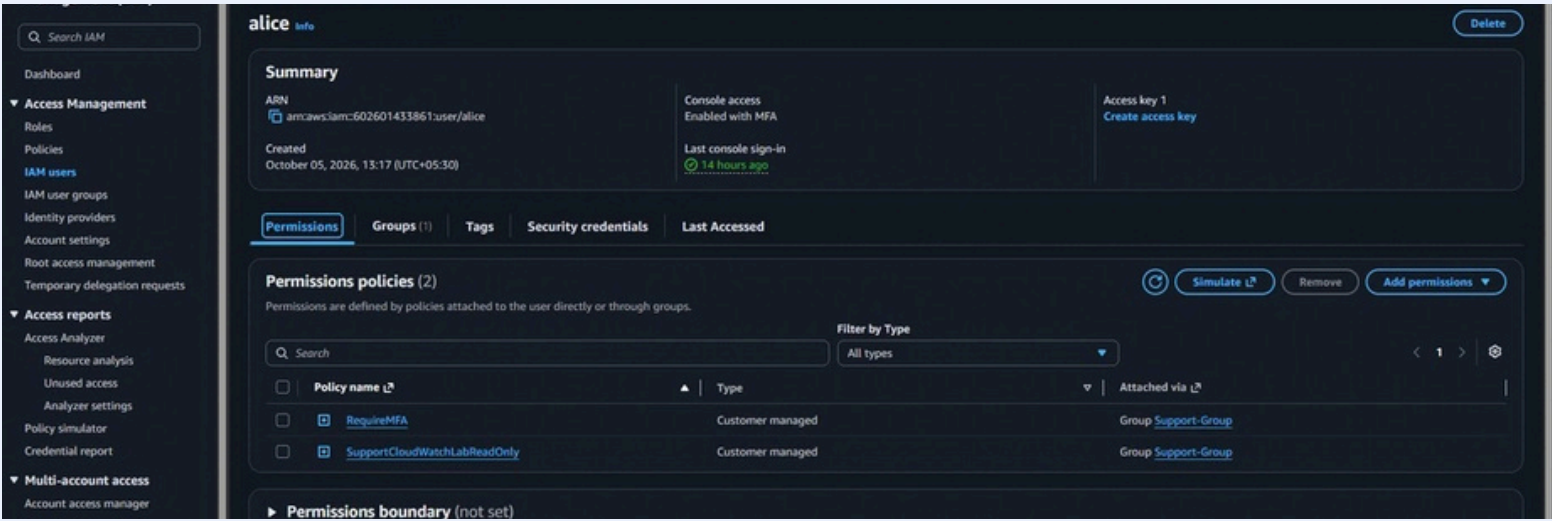
Action taken

- Baseline: member of Finance-Group only , Removed Finance-Group first, then added Support-Group

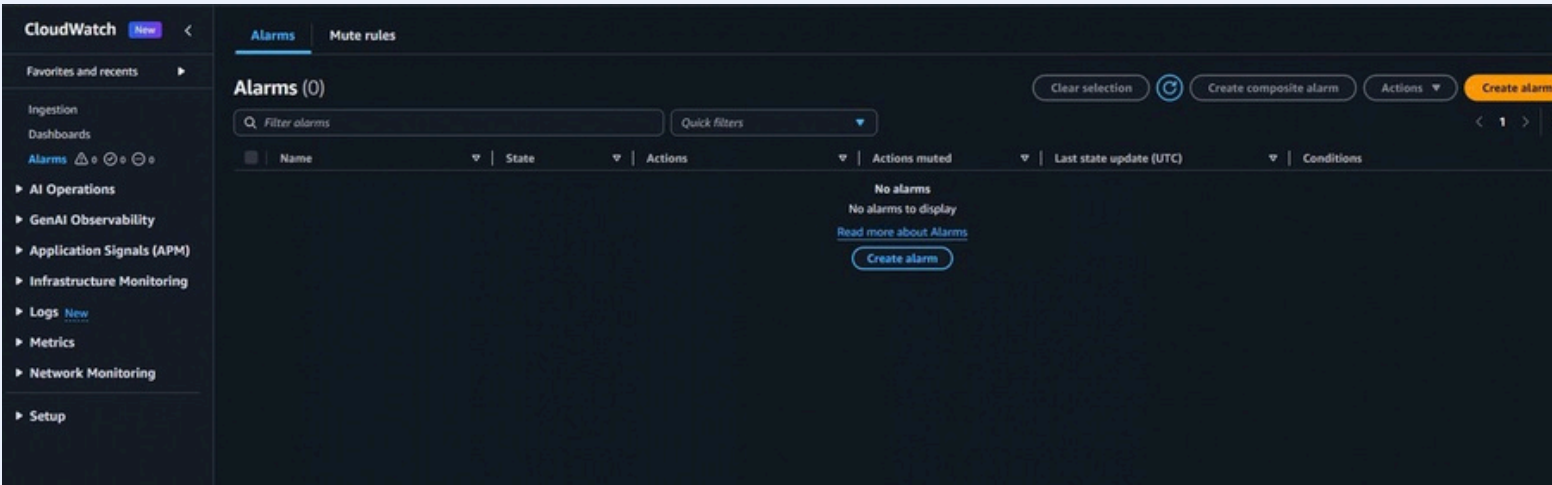
Verification

- CloudWatch access works
- Finance bucket now denied
- No Finance permissions remain

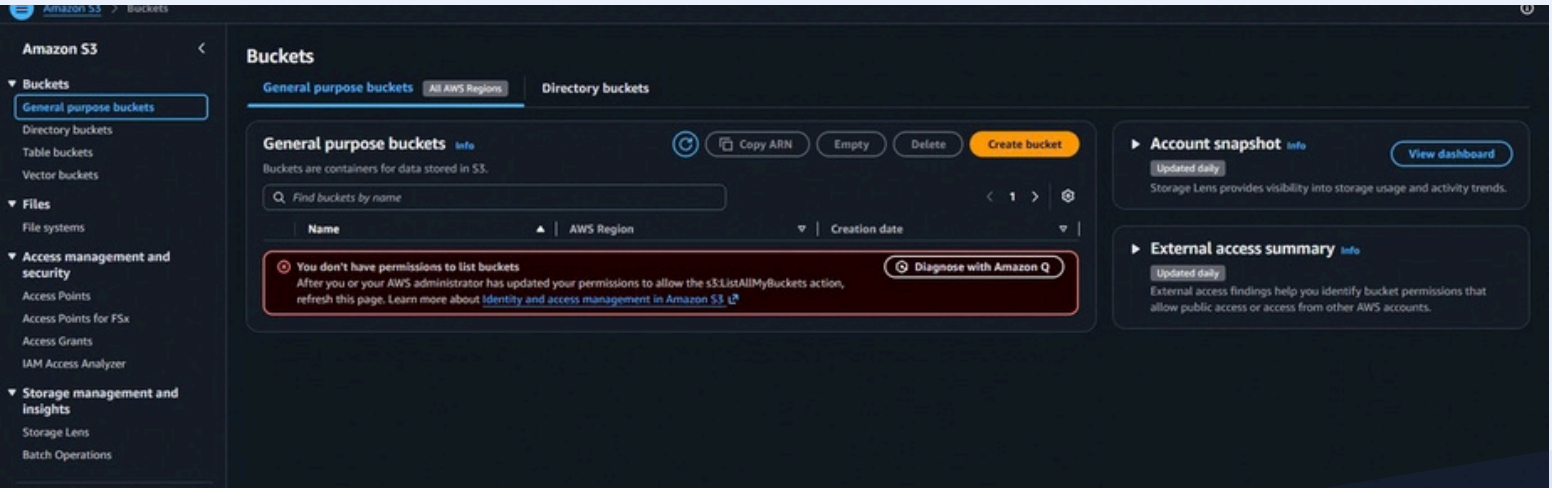
alice added to Support group



alice access test: CloudWatch allowed



S3 denied



IAM-003: Resignation, offboarding

Type	Leaver
User	charlie
Requested by	Support manager
Approved by	IAM admin
Date	06-10-26
Status	closed

Request

- charlie has left the company. All access must be removed.

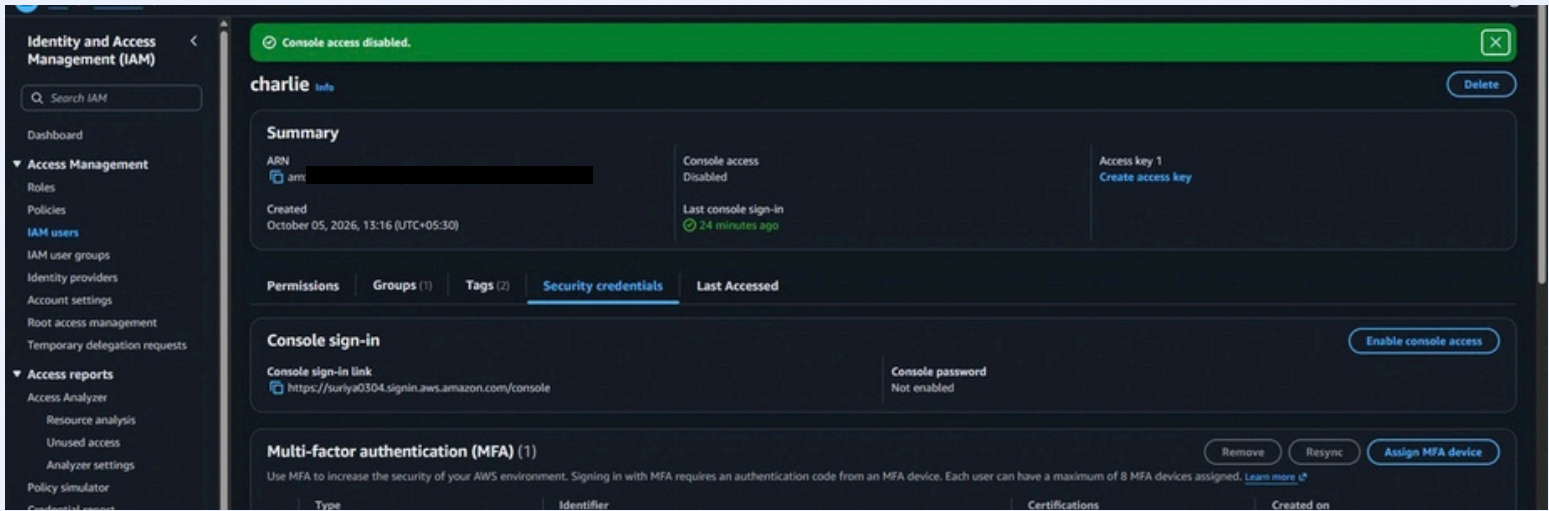
Action taken

- Disabled console access first (stops sign-in immediately)
- Removed the MFA device
- Checked access keys: none exist
- Removed Support-Group membership
- Kept the account for audit; deletion scheduled after the retention period

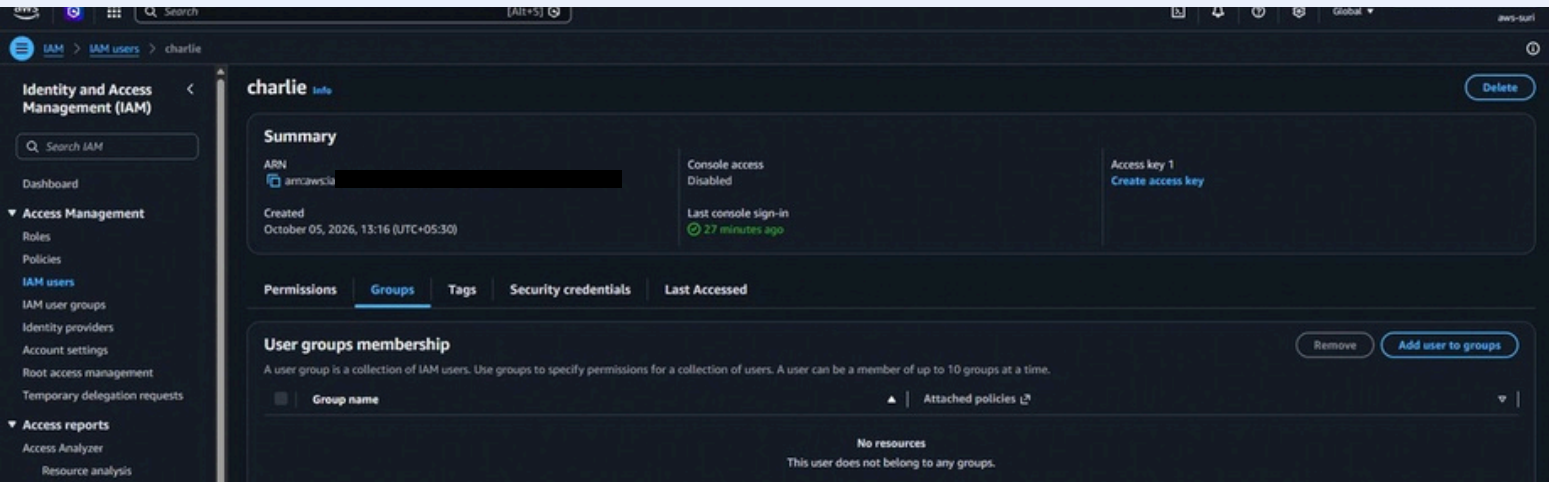
Verification

- Console access shows Disabled
- Permissions tab shows no policies
- Sign-in attempt fails

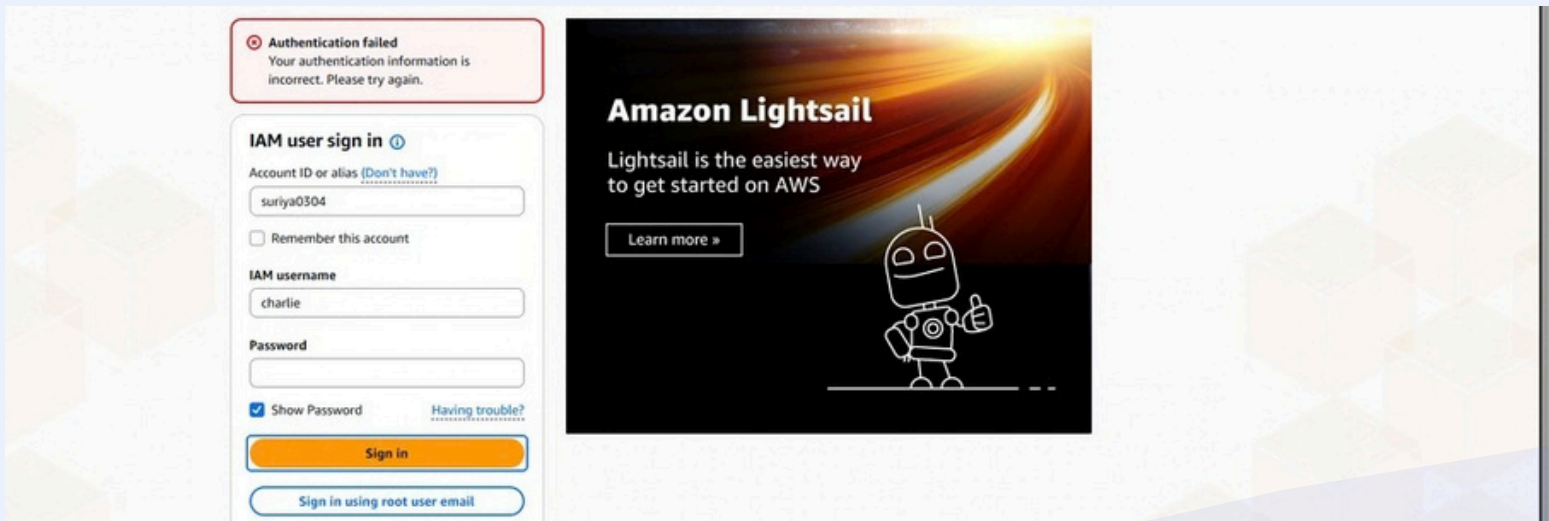
charlie: console access disabled



no groups or policies



charlie: failed sign-in attempt



IAM-004: AccessDenied on EC2 volumes

Type	Incident
User	bob bob(self-reported) IAM
Requested by	Admin
Approved by	Admin
Date	05-10-26
Status	Closed

Request

- Bob's EC2 dashboard showed Access denied on several tiles, including Volumes.

Investigation

- Checked Bob's group (Developer-Group) and its policy (DeveloperEC2LabReadOnly)
- Filtered CloudTrail event history on user bob and found the denied call
- Tested the action in the Policy Simulator

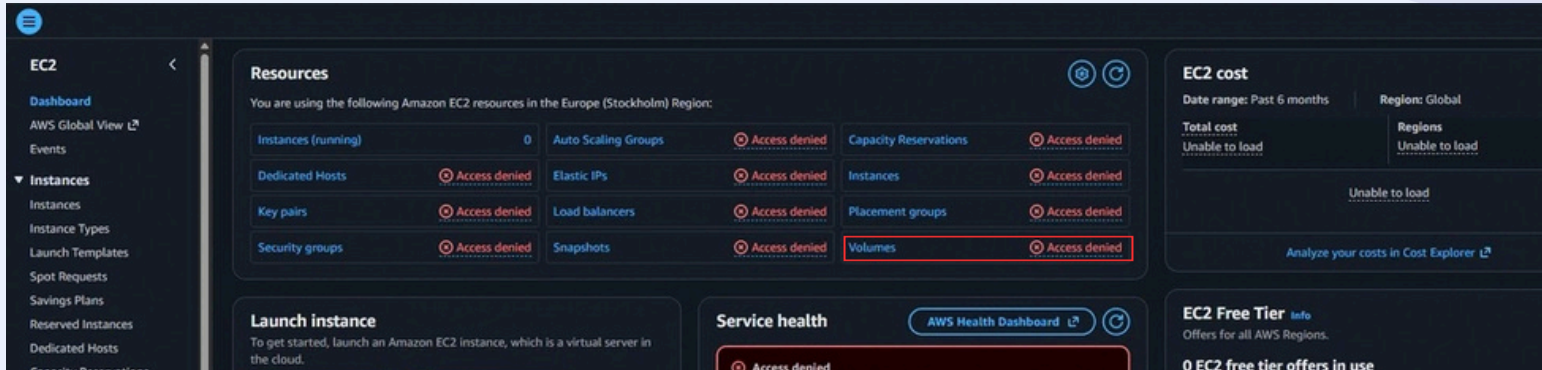
Root cause

- ec2:DescribeVolumes was missing from DeveloperEC2LabReadOnly, so the request was denied (implicit deny). The other denied tiles belong to services outside a developer's role and stay denied.

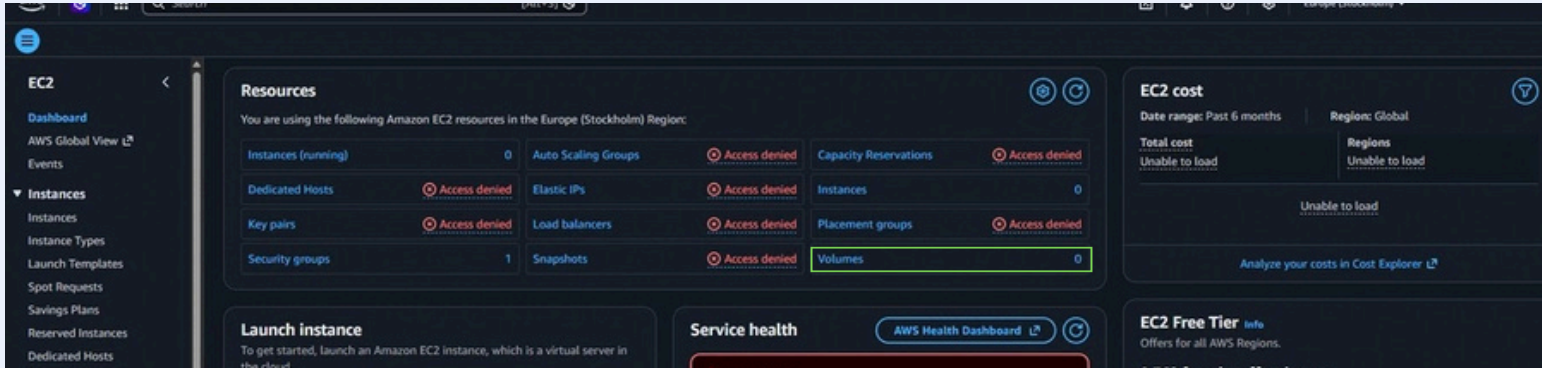
Fix

- Added ec2:DescribeVolumes to DeveloperEC2LabReadOnly.

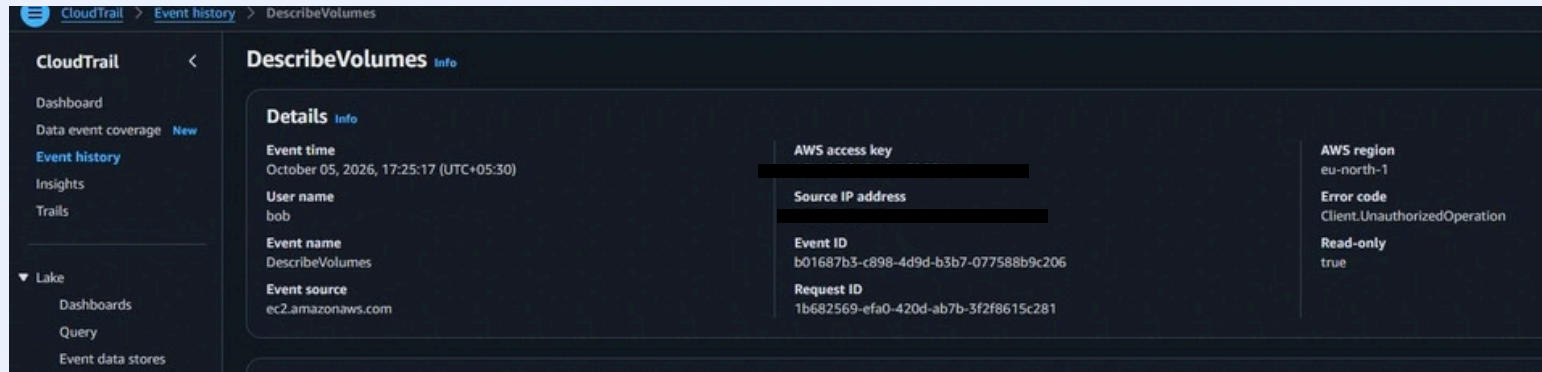
Dashboard with denied tiles (before)



Volumes tile loads (after)



CloudTrail event record with the AccessDenied error code



Verification

- Volumes tile loads in the EC2 dashboard.
- CloudTrail shows the denied call, then the successful call.

IAM-005:Temporary access through a role

Type	Role access
User	bob
Requested by	Approved
by Date	06-10-26
Status	closed

Request:

- Bob needs temporary read access to the finance bucket without a permanent finance permission.

Action taken:

- Created FinanceS3ReadRole (trusts this AWS account) with FinanceS3LabReadOnly
- Bob’s first Switch Role attempt failed
- CloudTrail showed an AssumeRole call with AccessDenied

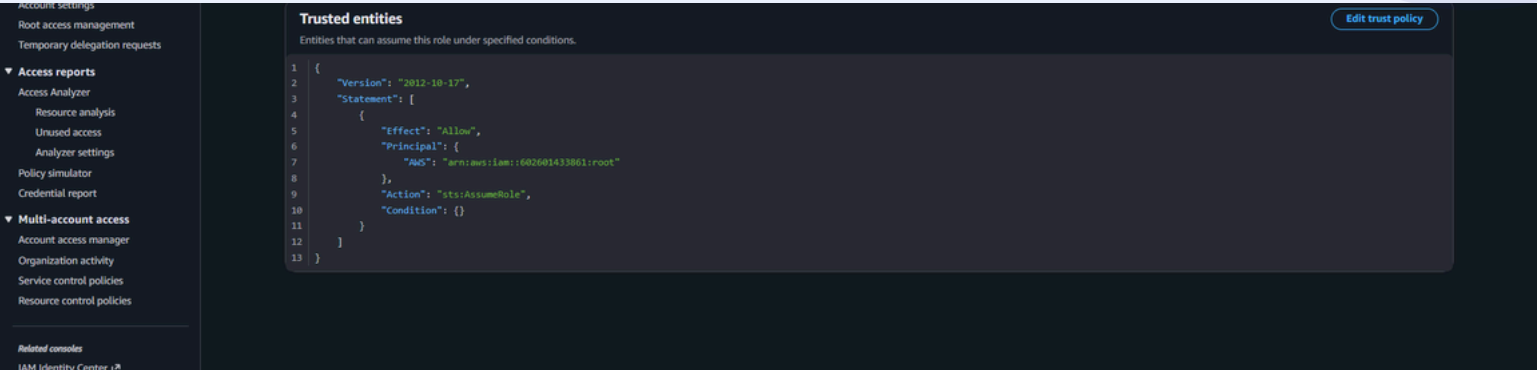
Root cause

- Bob’s identity policies had no sts:AssumeRole permission. The role’s trust policy was already correct.

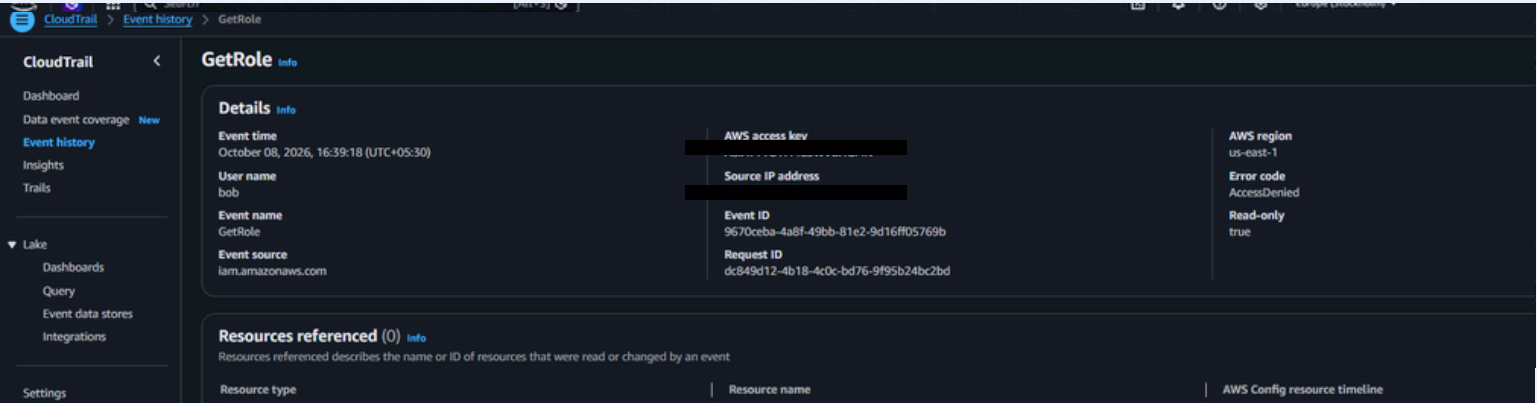
Fix

- created AllowAssumeFinanceS3ReadRole, scoped to the role ARN, and attached it to Developer-Group

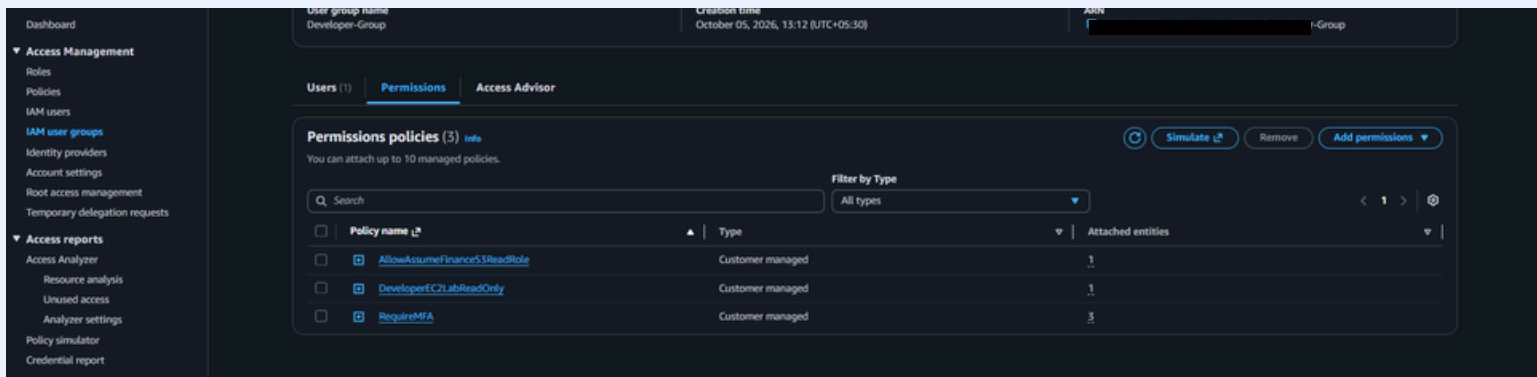
FinanceS3ReadRole trust and permissions tabs



Switch Role failing, with the CloudTrail AssumeRole event



AllowAssumeFinanceS3ReadRole attached to Developer-Group



Verification

- Switch Role works after signing in with MFA
- The role session reached S3
- Role sessions are temporary

IAM-006: S3 GetObject denied while using the role

GetObject AccessDenied error from S3

Type	Incident
User	bob
Requested by	bob(self-reported)
Approved by	IAM Admin
Date	06-10-26
Status	Closed

Problem

- Inside the role session, Bob could not read the object in the finance bucket.

Investigation

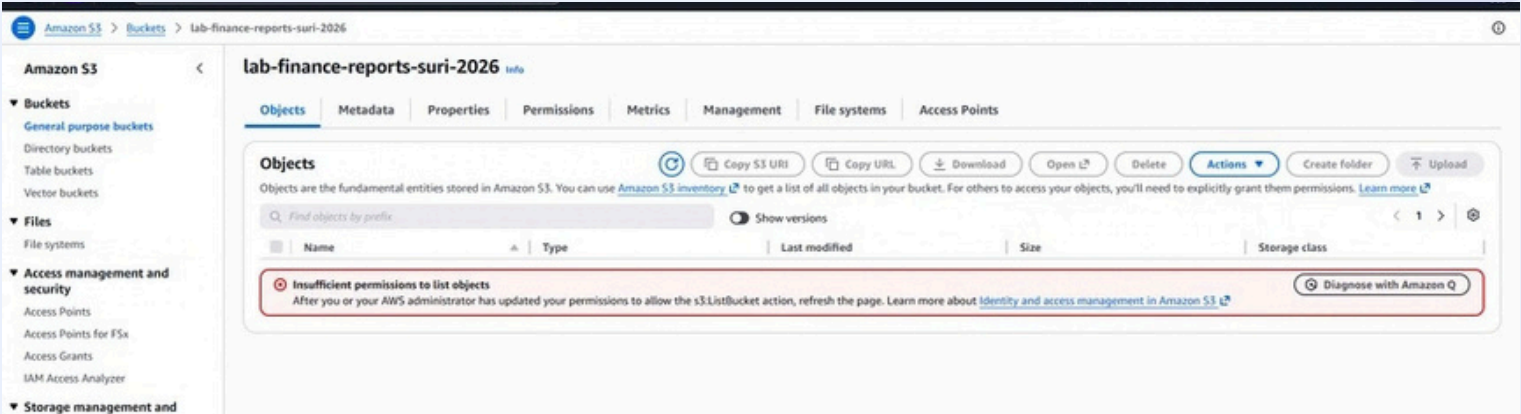
- The S3 error named the action (s3:GetObject), the object ARN and the cause: no identity-based policy allows it .
- Checked FinanceS3LabReadOnly: the resource list held the bucket and one specific object name

Root cause

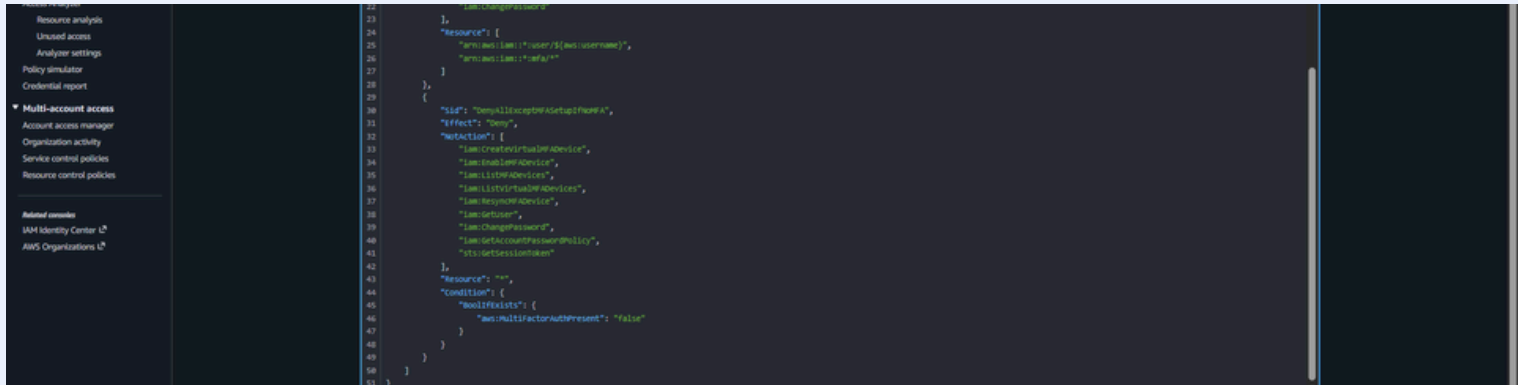
- The object resource matched a single object name, not the uploaded object.

Fix

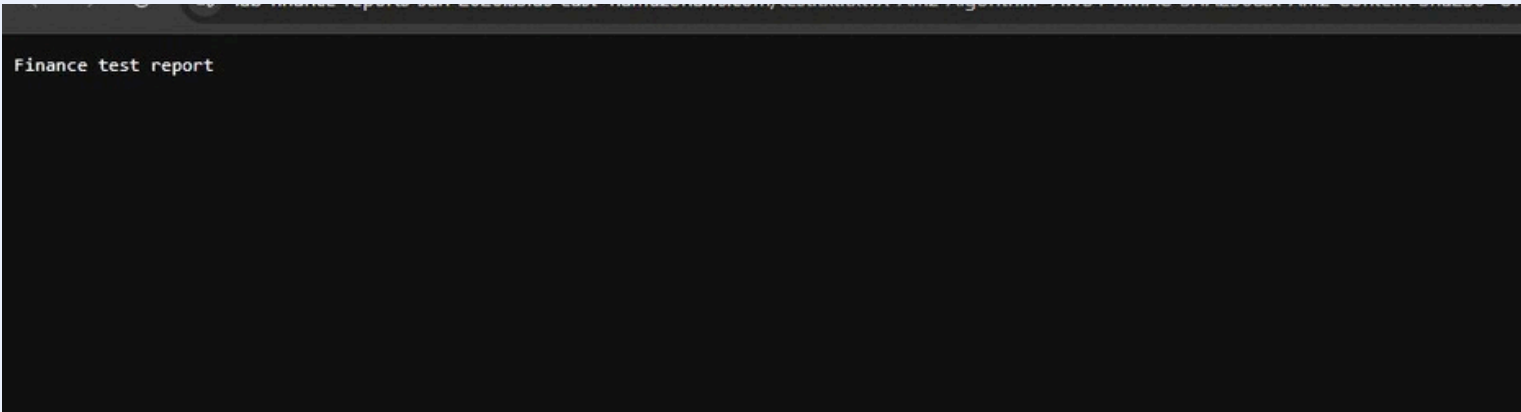
- Changed the object resource to every object in the bucket (bucket ARN followed by /*). The policy also applies to Finance-Group and is still limited to one bucket.



FinanceS3LabReadOnly with the corrected object resource



The file opening through the role



Verification

- After switching role again, the object opens through the role

IAM-007: Enforce MFA and password standards

Type	security
User	alice , bob , charlie
Requested	IAM Admin(Security control)
by Approved	IAM Admin
by Date	05-10-26
Status	Closed

Request

- Every lab user must use MFA and follow a password standard.

Action taken

- Created RequireMFA: explicit Deny on everything except MFA setup when MFA is absent
- Attached it to Finance-Group, Developer-Group and Support-Group (not to the admin group)
- Set the account password policy: 12+ characters, mixed types, 90-day expiry, last 5 passwords blocked, users may change their own password
- An admin enrolled Bob's MFA device, because the exception list blocked self-enrolment

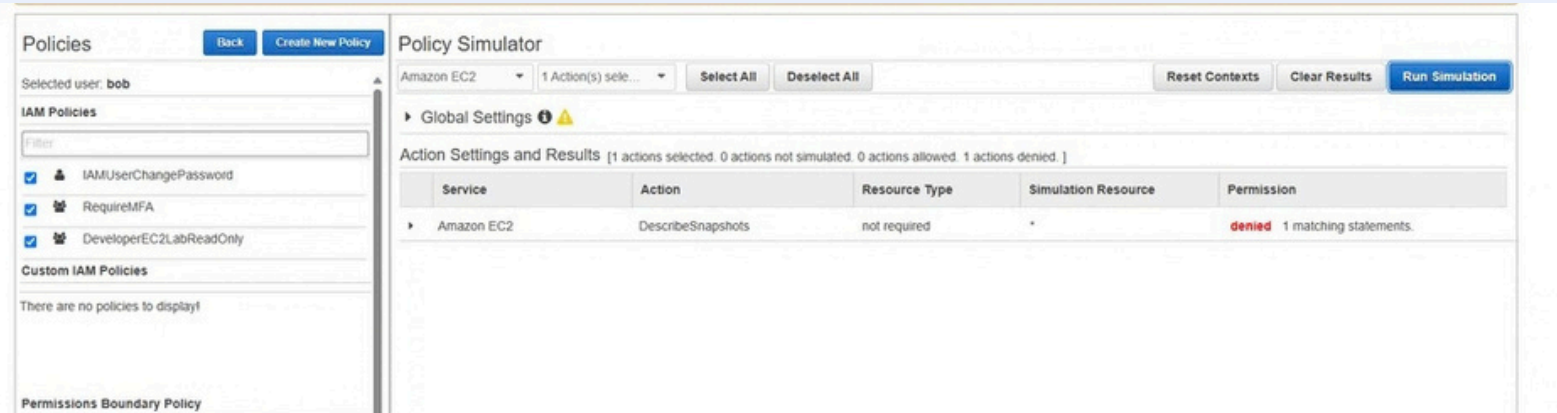
Follow-up

- The access review on 06-10-26 found RequireMFA missing from Developer-Group (finding F-02). It was re-attached. The cause was not traced.

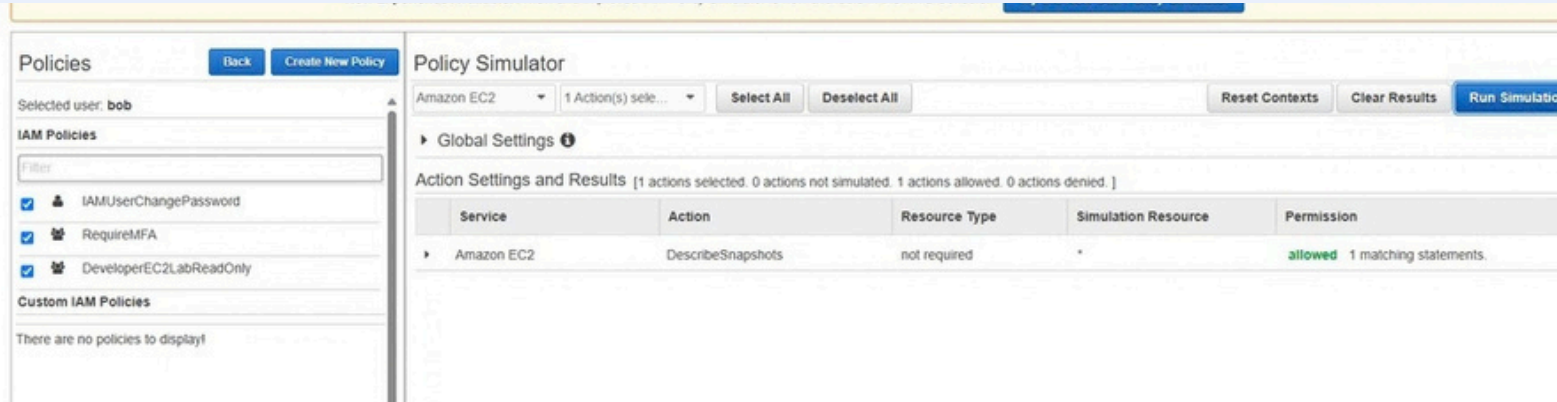
RequireMFA policy JSON

```
33  "iam:CreateVirtualMFADevice",
34  "iam:EnableMFADevice",
35  "iam:ListVirtualMFADevices",
36  "iam:ResyncMFADevice",
37  "iam:GetUser",
38  "iam:ChangePassword",
39  "iam:GetAccountPasswordPolicy",
40  "sts:GetSessionToken"
41  ],
42  "Resource": "*",
43  "Condition": {
44    "BoolIfExists": {
45      "aws:MultiFactorAuthPresent": "false"
46    }
47  }
48  }
49  }
50  }
51  }
```

“Policy Simulator: denied without MFA context (RequireMFA matches)



Policy Simulator: allowed with aws:MultiFactorAuthPresent = true



Verification

- Bob blocked without MFA (error names RequireMFA), allowed after MFA enrolment
- policy Simulator: denied without MFA context, allowed with aws:MultiFactorAuthPresent = true

Access Review and Governance:

Reviewed on 06-10-26 using the IAM credential report and each user's Permissions tab.
Checked: groups, direct policies, MFA, console access, access keys.

User	Groups	Direct Policies	Console/MFA	Keys	Decision
alice	Support-Group	None	Enabled/MFA on	None	Retain
bOb	Developer-Group	None(one removed)	Enabled/MFA on	None	Retain
charlie	None	None	Disabled/No MFA	None	Remove

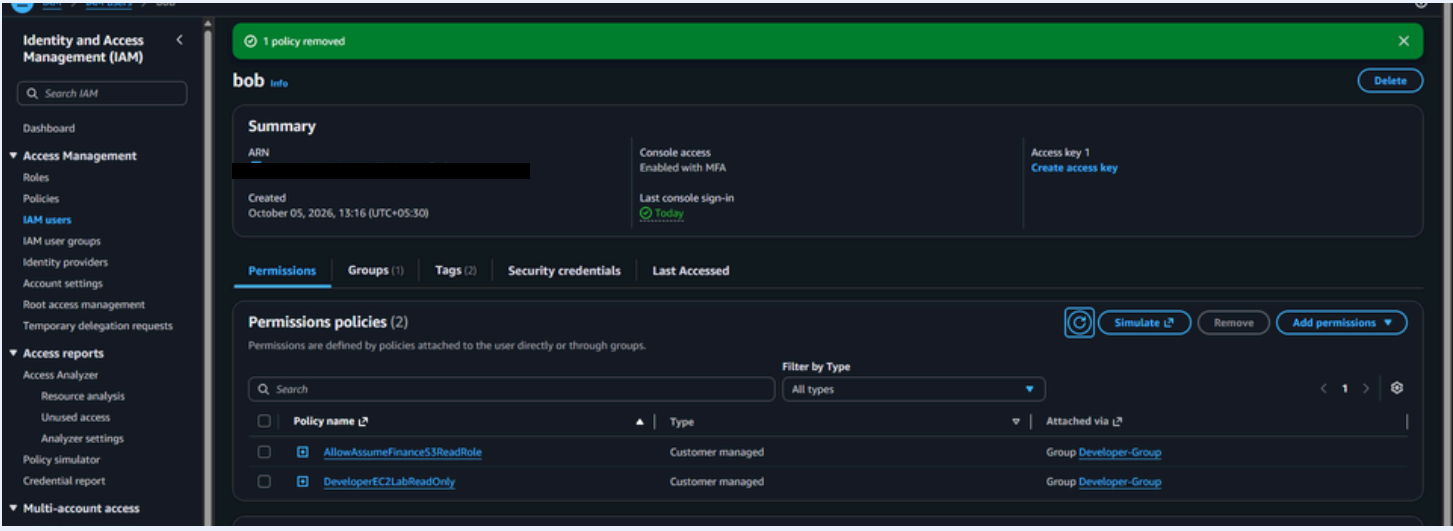
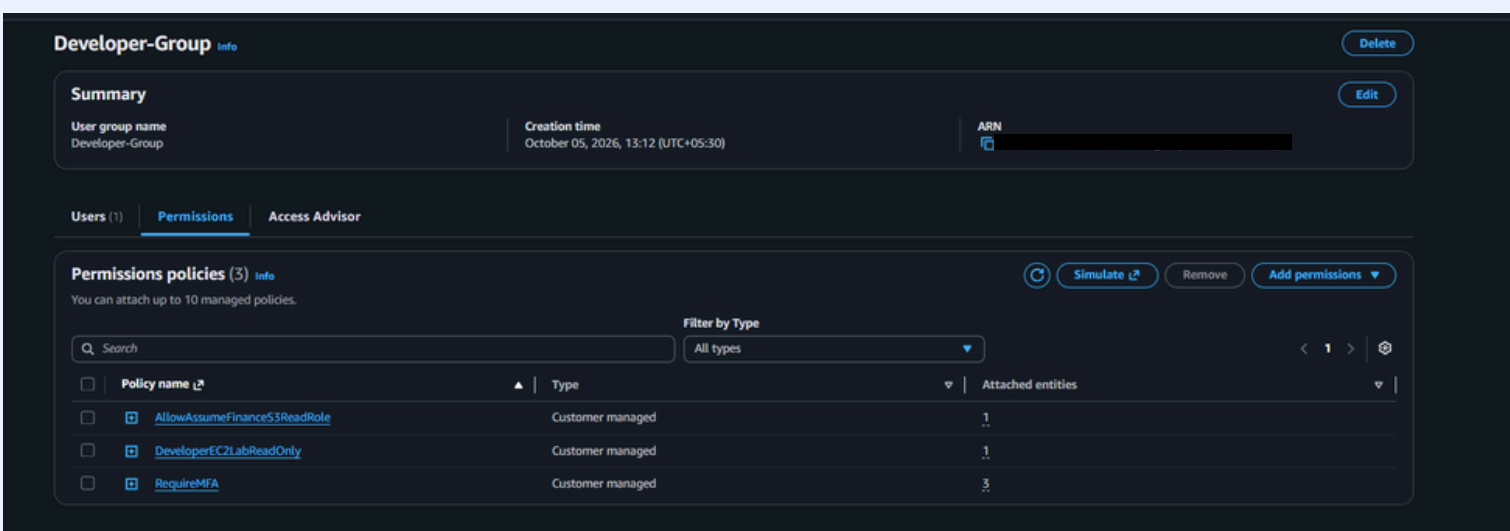
[illegible]

Review Findings:

Reviewed on 06-10-26 using the IAM credential report and each user's Permissions tab.
Checked: groups, direct policies, MFA, console access, access keys.

ID	Findings	Risk	Action	Status
F-01	bob had IAMUserChangePassword Attached directly	Low: bypasses group-based control	Detached	closed
F-02	RequireMFA missing from Developer-Group	Medium: MFA not enforced for developers	Re-attached (cause not traced)	closed
F-03	charlie's disabled account still exists	Low	Delete after the retention period	open

The review caught a control gap no ticket had flagged.



Manual Process, Benefits and Limits

- **Manual process:**

AWS Console only; ticket log with manual reviews; manual troubleshooting; a sample script was prepared but not used for these results

- **Benefits:**

- Security: less excess access, MFA enforced, faster leaver removal
- Operations: repeatable joiner/mover/leaver, clearer troubleshooting
- Audit: documented approvals, CloudTrail evidence, retain/remove decisions
- Cost: about zero

- **Limits:**

- Single account, small user set
- Fictional approvals
- Standing admin access remains (reviewed)
- An admin enrolled Bob's MFA because the exception list blocked self-enrolment
- Cause of F-02 not traced
- AD, Entra, SSO and SailPoint are concepts only

Conclusion

This project built a working AWS IAM environment and ran the full access lifecycle with documented approvals and evidence. Access is group-based and least-privilege, MFA is enforced for the three department groups, and the admin user also has MFA enabled, and temporary access to the finance bucket is given through a role instead of a permanent permission. Seven tickets were handled: three lifecycle changes (joiner, mover, leaver), three access problems (EC2 denied, role assumption, S3 object scope) and one security control (MFA and password standards). Each was investigated to its root cause, fixed with the smallest change and verified. The access review found a control gap that no ticket had flagged: RequireMFA was missing from Developer-Group. It was re-attached.

What it shows

- An explicit deny beats any allow, which is how MFA enforcement works
- Role access needs permission on both sides: the user and the role's trust policy
- Remove old access first when someone changes teams, and disable accounts before cleaning up
- Periodic reviews catch gaps that tickets miss

Final Result

What this project delivers

Deliverable	Result
A working IAM setup in AWS	4 users, 4 groups, 5 custom policies, 1 role, MFA enforcement and a password policy Evidence boxes on
Screenshot proof for each step	Screenshot evidence for each configuration, test and ticket
A complete ticket log and access review sheet	7 tickets closed (IAM-001 to IAM-007) and an access review with Retain or Remove decisions
An incident report	Problem, investigation, root cause, fix and verification for IAM-004 and IAM-006, plus the role case IAM-005
A report that explains the full flow	Request, approval, provisioning, verification, documentation, review and removal

Outcomes

Measure	Result
Lifecycle tickets completed	3 of 3 (joiner, mover, leaver)
Access problems resolved	3 of 3 (IAM-004, IAM-005, IAM-006)
Security control	IAM-007 closed: MFA and password standards enforced
Review findings needing action	3 raised: F-01 and F-02 fixed, F-03 open (charlie's account deleted after the retention period)
Active access keys	None
MFA	Enabled for every user who can sign in; RequireMFA enforced on the three department groups

Request, approval, provisioning, verification, documentation, review: every change in this lab followed that path.



Next Steps:

- *Automate joiner/mover/leaver with scripts or Terraform*
 - *EventBridge alerts when IAM policies change*
 - *Easier MFA self-enrolment*
 - *Time-limited admin access instead of standing admin*
 - *SSO and governance tooling*
 - *Cleanup once evidence is saved: delete the bucket, test users and role*
- 
- 



Thank You!

Secure Access • Compliant Operations • Stronger Governance

